Passive Reconnaissance of VulnApp Solutions Inc.

Target: VulnApp Solutions Inc.

Target URL: http://143.198.205.185/

Assessment Type: Passive Reconnaissance

Author: Malindu Wijayarathna

Date: 27th March 2026

Table of Contents

Contents i

1. Executive Summary 1

2. Reconnaissance Strategy 2

2.1 Information Gathering Framework 2

2.2 Legal and Ethical Considerations 2

2.3 Operational Security (OpSec) 3

2.4 Intelligence Objectives 3

2.5 Success Metrics 4

3. Tool Selection and Justification 5

3.1 Overview 5

3.2 Tool Selection by Category 5

A: Browser-Based Observation 5

B: Endpoint and Link Enumeration 5

C: Technology Stack Fingerprinting 6

D: Information Disclosure Documentation 6

E: Historical and Archive Analysis 6

3.3 Tool Comparison Table 7

4. Detailed Methodology 7

Phase 1: Initial Scoping 7

Phase 2: Application Structure and Endpoint Mapping 8

Phase 3: Information Disclosure Identification 9

Phase 4: URL Pattern and IDOR Analysis 10

Phase 5: Intelligence Correlation and Attack Surface Mapping 11

Integrated Mapping of Passive Findings, OWASP Categories, Severity, and Verification 11

Top 5 Active Tests Justified by Passive Findings 13

5. Technical Findings 14

5.1 /index.php - Public Structure Disclosure 14

5.2 /login.php - Verbose Error Disclosure and Missing CSRF Protection 14

5.3 /products.php - Internal Content Exposure and HTML Comment Leakage 15

5.4 /search.php - Reflected XSS Evidence 15

5.5 /profile.php - Insecure Direct Object Reference (IDOR) and PII Exposure 16

5.6 /admin.php - Unauthenticated Administrative Access 16

5.7 /ping.php - Publicly Exposed Network Utility 17

5.8 /upload.php - Public File Upload Function 17

5.9 Application-wide - No HTTPS 18

5.10 Application-wide - Server Disclosure 18

6. Risk Assessment Matrix 18

7. Recommendations and Active Scope 19

7.1 Recommendations 19

7.2 Active Assessment Scope 20

8. References and Appendices 21

8.1 References 21

Standards and Guidance 21

Tools and External Sources 21

8.2 Appendices 21

Appendix A - URL List 21

Appendix B - HTTP Header Evidence 22

Appendix C - Other Evidence 24

1. Executive Summary

This report presents the findings of a passive reconnaissance conducted on an externally available web application of VulnApp Solutions Inc, which is hosted at http://143.198.205.185/. The objective was to identify publicly accessible information, architecture of application, and possible security vulnerabilities without actively exploiting or performing any active intrusion.

This assessment revealed the security posture is at high risk, and several critical vulnerabilities were identified within context of passive interaction. Notably, an administrative interface /admin.php was found publicly accessible and exposes sensitive backend data to any user. This represented an extreme access control measure failure.

Significant amount of confidential user data was publicly disclosed without any authentication, including the Personal Identifiable Information (PII) and financial data. The observed data can be categorized as usernames, email addresses, user roles, account identifiers, credit card details including numbers and Social Security Numbers (SSNs).

Overall, over 5 sensitive data fields per user record were publicly available in /profile.php and /admin.php. This shows that data protection and privacy controls have failed seriously to ensure data protection and privacy. Two hidden endpoints, /page.php and /info.php were able to identify, which reveals dynamic file-loading behavior and sensitive server configuration details.

Additionally, this application exhibits insecure design patterns, including predictable URL parameters (profile.php?id=) which enables enumeration of user profiles, and high likelihood of Broken Access Controls. The verbose error messages that are observable on login page further disclose backend SQL query structures, which increases the risk of injection-based attacks.

Absence of HTTPS encryption increases risks by allowing sensitive data including user credentials and session identifiers to passed as plain texts. Furthermore, lack of security headers and poor session management enhance probability of client-side attack and session hijacking.

Overall, this application exhibits critical risk rating, requiring immediate remediation before an attacker accesses sensitive administrative and user data, enumerate user accounts and extract PII, gain unauthorized administrative access, exploit insecure input handling mechanisms. This report provides a detailed breakdown of the identified issues, along with the recommended remediation strategies that can be taken and a scoped plan for subsequent active security testing.

2. Reconnaissance Strategy

2.1 Information Gathering Framework

A structured, phased passive reconnaissance approach was conducted to evaluate the VulnApp web application that is running on a bare IP address (http://143.198.205.185/). Without ant domain, any SSL/TLS, and other external metadata (e.g.: WHOIS), the sole source of intelligence gathering was relied on the application layer observations.

The stages included in the framework were:

1. **Initial Discovery -** The homepage /index.php was analyzed to identify the purpose of this application, visible disclosures, and the navigation structure.
2. **Endpoint Enumeration -** The navigation menu was used as the primary source of enumeration. All the linked endpoints were accessed systematically: /index.php, /login.php, /products.php, /search.php, /profile.php, /admin.php, /ping.php, /upload.php.
3. **Source Code Analysis -** The HTML source codes of each endpoint were inspected to identify hidden comments, developer notes, additional connected endpoints, form actions and parameters.
4. **Parameter identification -** The URLs were examined to identify input parameters (e.g.: profile.php?id=1, search.php?q=test).
5. **Response Observation -** Using the browser developer tools the HTTP responses were captured and used to extract the headers and infer backend technologies.

With this approach it ensured the complete enumeration of publicly exposed functionalities without triggering and server-side processing by going beyond normal browsing

2.2 Legal and Ethical Considerations

This assessment strictly adhered to passive reconnaissance principles, ensuring that there will be no unauthorized contact with the application.

- **Boundary Definition:** Passive reconnaissance involved browsing the publicly accessible endpoints, Inspecting HTML sources and observing the HTTP responses. Active exploitations such as (e.g.: SQL injection, XSS payloads, Authentication bypassing) were not explicitly allowed.

- **Sensitive Data Handling:** Any discovered sensitive data such as (e.g.: Credit card numbers, SSNs) were handled responsibly by not reproducing in full, redacting in documentation and using only for classification and risk assessment.
- **Admin Panel Access Justification:** Accessing the (/admin.php) does not account for an exploitation, as it is publicly accessible without any authentication. The ethical responsibility lies in documentation of the exposure, not interacting with or modifying the data.

This approach ensures compliance with passive reconnaissance and professional conduct.

2.3 Operational Security (OpSec)

To avoid generating detectable artifacts, the following OpSec measures were taken:

- **Clean Browser Environment -** A fresh browser profile was created and used to eliminate any cached sessions or any cookies.
- **Passive Interaction Only -** During the process only standard navigation and minimal input such as (e.g.: simple searches, failed login) were performed.
- **No Automated Scanning -** For this purpose, no tools such as Nmaps, fuzzers, or vulnerability scanners were used.
- **Controlled Data Storage -** Screenshots that were captured and the sensitive findings were securely stored and handled locally to ensure no data leakage.

Through these measures it ensures that the reconnaissance actively remains indistinguishable from the normal user's behavior.

2.4 Intelligence Objectives

The assessment aimed at achieving the following measurable objectives:

- **Enumeration of all publicly accessible endpoints and resources -** Identifying and documenting all the pages, resources, unauthenticated accessible functionalities of the application using navigation links, visible hyperlinks, and HTML source analysis.
- **Identify all data types that are exposed without authentication -** Log all the categories of information disclosed through the application, including user data, information on system, and sensitive data such as PII or financial details.

- **Detection of URL parameter patterns indicating insecure design -** Detection and documentation of all user-controllable input parameters (e.g.: query strings) and evaluation of their structure, predictability, and potential for Insecure Direct Object Reference (IDOR) or injection risks.
- **Extraction of internal infrastructure and application details -** Identifying backend technologies, server configurations, and server level information through passive observation of HTTP response headers, HTML source codes, and application behaviors.
- **Identification of potential attack vectors through passive observation -** Gathering of possible security weaknesses, including injection points, access control flaws, and misconfigurations, based solely on the application behavior that was observed without performing active exploitation.

2.5 Success Metrics

Passive reconnaissance that conducted was considered complete when the following measurable conditions were satisfied:

- **All publicly accessible navigation endpoints were fully enumerated** - /index.php, /login.php, /products.php, /search.php, /profile.php, /admin.php, /ping.php, and /upload.php.
- **HTML source codes of every endpoint are thoroughly inspected** - hidden elements such as comments, additional links, form actions, and developer notes.
- **HTTP response headers were observed and analyzed in endpoints** - key headers such as Server, and Content-Type, to infer backend technologies and configurations. Identification, documentation, and classification of all URL parameters - parameter patterns (e.g., id, q) to assess potential insecure design and access control weaknesses.
- **All unauthenticated and exposed data types are catalogued** - user data, roles, and sensitive information categories such as PII and financial data.
- **Endpoints that are hidden or non-obvious were identified using passive techniques** - HTML source analysis and logical inference (e.g., development or configuration files).
- **No additional endpoints or data exposures could be identified further through passive observation** - publicly accessible attack surface had been comprehensively mapped.

3. Tool Selection and Justification

3.1 Overview

The toolset for this assessment was chosen carefully to align with the passive reconnaissance constraints so that the entire data collection should have been conducted in non-intrusive ways. These tools emulate the behavior of a normal user or analyses the responses that are already available without any active probing or exploitation.

3.2 Tool Selection by Category

A: Browser-Based Observation

Tools Used - Google Chrome (Developer Tools), Mozilla Firefox, Burp Suite (Passive Proxy).

Justification - These browser-based tools are essential for analyzing HTML source codes, HTTP response headers, URL structures, and parameters for conducting the passive reconnaissance. Google Chrome DevTools enables real-time inspection of network traffic, including the headers such as server and Content-Type. Mozilla Firefox was used for cross validation of behavior of the application across browsers. Burp Suite (Passive Mode) allowed interception and detailed inspection of HTTP requests and responses without modifying them.

Stealth Advantage - all tools are operated with normal browser traffic, no abnormal requests or scanning patterns are generated, activity is indistinguishable from a regular user session.

Limitations - Manual analysis required, limited automation, deeper vulnerabilities cannot be detected without active scanning.

B: Endpoint and Link Enumeration

Tools Used - Manual Navigation (Menu), HTML Source Inspection, Browser DevTools.

Justification - As this is a passive reconnaissance, endpoints were discovered using navigation menu links, embedded hyperlinks in HTML and form action attributes. Through HTML source inspection it revealed hidden endpoints, developer comments, and additional paths.

Stealth Advantage - No automated scanning or brute force requests, entirely relies on application content, complaint with passive reconnaissance rules.

Limitations - Deeply hidden endpoints could be missed, depending on the mistakes of developer (e.g.: exposed links), time-intensive manual process.

C: Technology Stack Fingerprinting

Tools Used - Wappalyzer (Extension), HTTP Response Headers, Error Message Analysis.

Justification - Technology identification was performed passively using HTTP headers (e.g.: Apache, PHP), file extension (.php), error messages revealing backend logic. While the headers confirmed the server configurations, Wappalyzer provided quick identification of technologies.

Stealth Advantage - No direct probing or fingerprints scans, information that uses is already disclosed by the server.

Limitations - Limited accuracy on hidden technologies, without active scans no deep fingerprinting.

D: Information Disclosure Documentation

Tools Used - GoFullPage (Screenshots), SingleFile (Page Archiving), Local Secure Storage.

Justification - Accurate documentation is essential for the purpose of evidence collection, report validation, and reproducibility. Using GoFullPage tool, full page screenshots were captured for visual evidence collection. SinglePage preserved complete HTML pages for offline analysis. **Stealth Advantage** - No interaction with the target server other than normal browsing, processing and documentation was conducted locally.

Limitations - Static captures only, various sized files are stored.

E: Historical and Archive Analysis

Tools Used - Wayback Machie, Shodan

Justification - For retrieving historical data and infrastructure data of the web application these tools were used. Wayback Machine returned no archived data on the target, by confirming the absence of a public historical footprint. Shodan provided useful infrastructure insights, identifying server as a DigitalOcean-hosted Linux system (Singapore) with port 22 (SSH) exposed, which contributes to the external attack surface.

Stealth Advantage - Completely external to the target, no interaction with the infrastructure.

Limitations - No historical data available for bare IP, limited results for this specific target.

3.3 Tool Comparison Table

Category	Tool	Purpose	Stealth Adv.	Limitation
Browser-Based Observation	Chrome DevTools	Inspect headers, requests, source	Native browser activity	Manual analysis
	Burp Suite (Passive)	Capture HTTP traffic	No active scanning	No automation
Endpoint and Link Enumeration	Manual Navigation	Discover endpoints via UI	Normal user behavior	Limited coverage
	HTML Source	Find hidden links/comments	No server interaction	Time-consuming
Technology Stack Fingerprinting	Wappalyzer	Detect technologies	Passive detection	Limited accuracy
	HTTP Headers	Identify server/backend	Already exposed data	Limited detail
Info. Disclosure Documentation	GoFullPage	Capture screenshots	Local processing	Static only
	SingleFile	Save full pages	Offline analysis	Large files
Historical and Archive Analysis	Wayback Machine	Historical data	External tool	Ineffective for bare IP
	Shodan	Infrastructure information	Passive querying	Limited results

4. Detailed Methodology

This methodology outlines a structured, reproducible passive reconnaissance approach which was conducted against the target web application (http://143.198.205.185/).

Phase 1: Initial Scoping

This process began by confirming the target and establishing scope of passive reconnaissance.

1. Controlled browser environment was prepared before accessing the target URL by taking various measures such as creating a clean browser environment, enabling developer tools

(Network and Elements tabs), Configuring Burp Suite in passive proxy mode, and preparing screenshot tools for evidence collection.

2. The target URL http://143.198.205.185/ was first accessed on the 23rd of March 2026 at 15:19 P.M. and was recorded to ensure consistency, as bare IP-hosted applications may change over time.
3. The home page (/index.php) was loaded and analyzed, including the application name, which is VulnApp, purpose of the application as E-Commerce platform (Widget Marketplace) and the navigation structure was linked with various endpoints including very sensitive endpoints without any authentication or secure controls.
4. Thereafter, publicly accessible resources that can be accessed through direct navigation, hyperlinks present in the application, viewing HTML source and observing HTTP responses without performing any authentication bypasses or payload submissions were accessed.

Phase 2: Application Structure and Endpoint Mapping

The structure of this target was systematically analyzed by enumerating all publicly accessible endpoints through all visible navigation elements, hyperlinks, and application responses.

First, the navigation menu was completely recorded as the primary enumeration source, revealing the following endpoints: [/index.php (Home), /login.php (Login), /products.php (Products), /search.php (Search), /profile.php (User Profile), /admin.php (Admin Panel), /ping.php (Network Tools), /upload.php (File Upload)]. Each of these endpoints were accessed individually through standard browser navigation and were documented in detail.

The title of the page and its primary functionality of each endpoint were analyzed. This target application exposes variety of data types across different pages, which includes product information, username, user roles, and personal identifiable information (PII) categories such as emails and financial related details such as credit card details. Sensitive data was observed without any authentication, particularly within profile, product, and admin endpoints.

The full URL structures were carefully documented and analyzed including any query parameters where applicable. For example, the profile page uses a parameterized format (http://143.198.205.185/profile.php?id=2), indicating the dynamic content that is loading based on user identifiers. The “id” parameter follows a predictable numeric pattern, suggesting a

sequential access to user records. Similarly, other endpoints such as search functionality indicate parameter driven behavior, although no active manipulation was performed.

HTML source of every endpoint was inspected using browser's "View Page Source" functionality. This included analysis of HTML comments, hidden fields, additional "href" links, and form "action" attributes. Through this it revealed backend logic, navigation flows, potential hidden endpoints, and comments provided insights into backend functionality and application behaviors (e.g.: CSRF vulnerability, Secret Widgets, etc....).

HTTP response headers were captured using browser Developer Tools and Burp Suite passive mode. Key headers such as Server, Content-Type were observed, with the server header indicating as Apache/2.4.58 (Ubuntu), confirming the backend web server environment. Wappalyzer browser extension was also used. The X-Powered-by header was absent, suggesting that backend technology transparency has been intentionally restricted. Additionally, no Strict-Transport-Security (HSTS) header was observed, and all the responses were transmitted over HTTP, confirming the absence of encryption and it indicates weak transport security and increases chance of interception attacks.

The accessed URL and associated resources that were logged and recorded *(View References and Appendices)*. This documentation ensured complete visibility of the application's externally exposed structure while maintaining strict adherence to passive reconnaissance constraints.

Phase 3: Information Disclosure Identification

Here, all the information exposed by the application without authentication was identified through passive observation and documented.

- The home page (/index.php) declared itself as a security training platform and listed multiple vulnerability categories that should not be included and exposed. It contained multiple endpoints linked through the navigation menu. The passive observation confirmed that it links with several sensitive endpoints which were directly accessible, including /profile.php, /admin.php, /ping.php, and /upload.php. Exposure of these unauthenticated navigations indicated weak segregation between public and sensitive application areas.

- The products page (/products.php) displayed product names descriptions and prices, including potentially sensitive or internal data which should not be displayed. HTML source inspection revealed additional comments and structural elements that should not be included.
- The admin panel (/admin.php) was accessible without any authentication and exposed all sensitive user related data in a tabular format, including usernames, passwords, email addresses, roles, and other sensitive financial data. This represents highly sensitive information and indicates a critical lack of access control.
- The profile page (/profile.php) revealed user specific data through a parameterized URL (http://143.198.205.185/profile.php?id=2). These pages exposed multiple PII categories, and predictable numeric "id" parameter suggests the sequential access to user records, indicating potential unauthorized data exposure.
- The login page (/login.php) returned with verbose error messages when tested with dummy credentials which reveal the information about authentication behavior. Through HTML source inspection, it exposed form structures and its input handling mechanism.
- Across all pages, additional internal details were identified, including application structure patterns, PHP-based endpoints, and Apache server usage. The application was running over HTTP without encryption, which increases the risk of data interception.

Phase 4: URL Pattern and IDOR Analysis

The URL structure of this application was analyzed to identify insecure design patterns through passive observation without injecting any manipulated inputs.

The (/profile.php) endpoint uses a parameterized URL structure in the form of http://143.198.205.185/profile.php?id=2, where the "id" parameter in here is a numeric value. This pattern indicates a sequential integer-based identifier, which suggests that the user records are indexed in an incremental manner. Each of these ids corresponds to a distinct user profile, exposing multiple categories of data such as PII, and other financial data. This page lacks explicit pagination controls, and this predictable "id" parameter inherently enables enumeration.

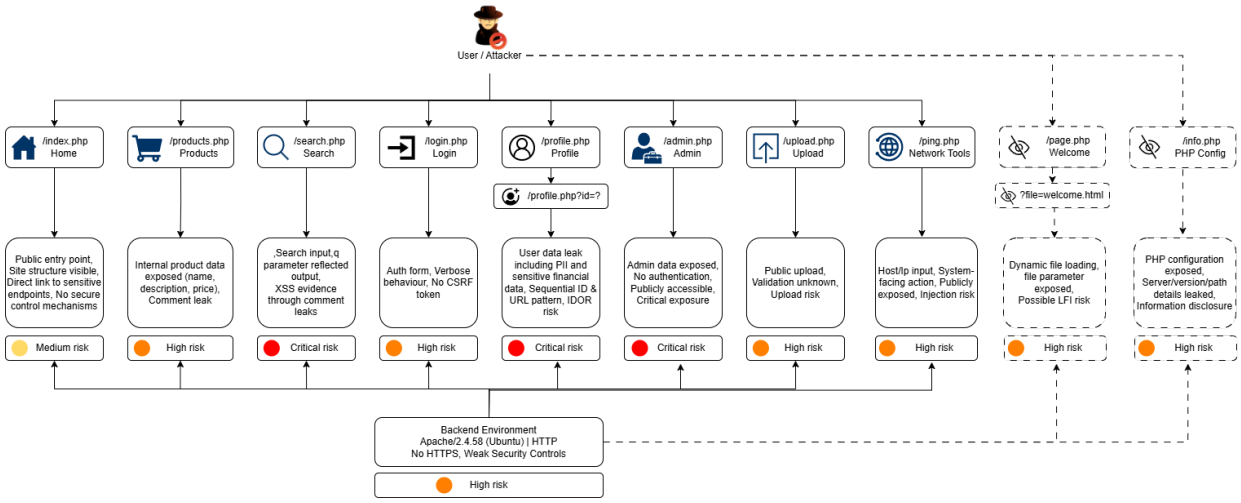
The admin panel (/admin.php) which is directly accessible through navigation menu without any authentication shows that there is no viable access control mechanism applied on routing or

presentation layer of this architecture. This is a serious fundamental flaw in access control design where the sensitive administrative functionality is not segregated from public access.

Other endpoints such as the search (/search.php), also suggest parameter driven behavior, although parameters are not necessarily always visible in the navigation. Form based endpoints such as (/login.php) and (/upload.php) also implies backend parameter handling through POST requests, which can be observable through HTML source.

This design presents high risk of Insecure Direct Object Reference (IDOR). An attacker can gain unauthorized access to several user records by testing different values for the "id" parameter. The impact is also significant since the data that are being exposed are very sensitive. Lack of authorization checks and predictable URL patterns confirm a high-severity IDOR risk.

Phase 5: Intelligence Correlation and Attack Surface Mapping



Integrated Mapping of Passive Findings, OWASP Categories, Severity, and Verification

Homepage Disclosed / Finding	Passive Evidence	OWASP Category	Severity	Verification Status
SQL injection	login returns verbose backend query during failed authentication, indicating unsafe input handling and possible SQL-related exposure.	A03 Injection	High	Suggested, Requires active testing

Reflected XSS	HTML source of /search.php explicitly includes comments indicating reflected XSS and un-sanitized output.	A03 Injection	Critical	Confirmed passively
Local File Inclusion (LFI)	A hidden endpoint, /page.php, exposes a user-controlled file parameter through on-page guidance (?file=welcome.html), indicating dynamic file-loading behavior and possible file inclusion risk.	A04 Insecure Design	High	Suggested, Requires active testing
IDOR / Profile Access	/profile.php provides direct links to other user profiles through predictable numeric identifier and exposes different user records through sequential values, including sensitive user-related data.	A01 Broken Access Control	Critical	Confirmed passively
Command Injection	/ping.php exposes network utility functionality that accepts host/IP input, indicating a likely command execution surface.	A03 Injection	High	Suggested, Requires active testing
Authentication Bypass / Missing Access Control	Sensitive administrative functionality (/admin.php) is directly accessible without authentication, indicating absence of effective access control.	A01 Broken Access Control / A07 Identification and Authentication Failures	Critical	Confirmed passively
Insecure File Upload	/upload.php is publicly accessible and exposes upload functionality without visible restrictions or access control.	A05 Security Misconfiguration / A04 Insecure Design	High	Suggested, Requires active testing
Sensitive Infrastructure Services	Shodan identified exposed SSH service on port 22 and infrastructure details including DigitalOcean hosting, Linux OS, and public IP metadata.	A05 Security Misconfiguration	Medium	Confirmed passively
No CSRF Protection	HTML source of /login.php explicitly includes a comment noting the absence of a CSRF token.	A04 Insecure Design / A07 Identification and Authentication Failures	High	Confirmed passively

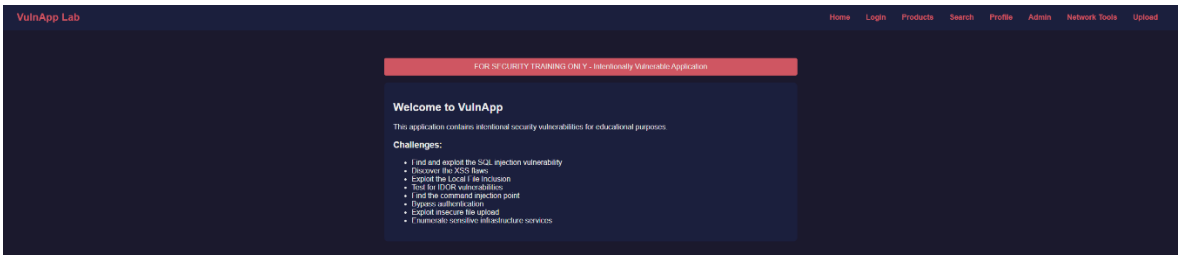
PII Exposure	/profile.php and /admin.php expose personally identifiable and account-related data without authentication or authorization controls.	A01 Broken Access Control / A02 Cryptographic Failures	Critical	Confirmed passively
No HTTPS	The application is served over HTTP, and no transport encryption is enforced.	A02 Cryptographic Failures	High	Confirmed passively
HTML Comment Leakage	HTML source reveals internal comments such as instructions to hide a product from non-admin users and vulnerabilities	A05 Security Misconfiguration	Low	Confirmed passively
Server Configuration Disclosure	The hidden endpoint /info.php exposes PHP configuration details, including PHP version, Apache version, configuration paths, environment variables, and loaded modules.	A05 Security Misconfiguration	High	Confirmed passively

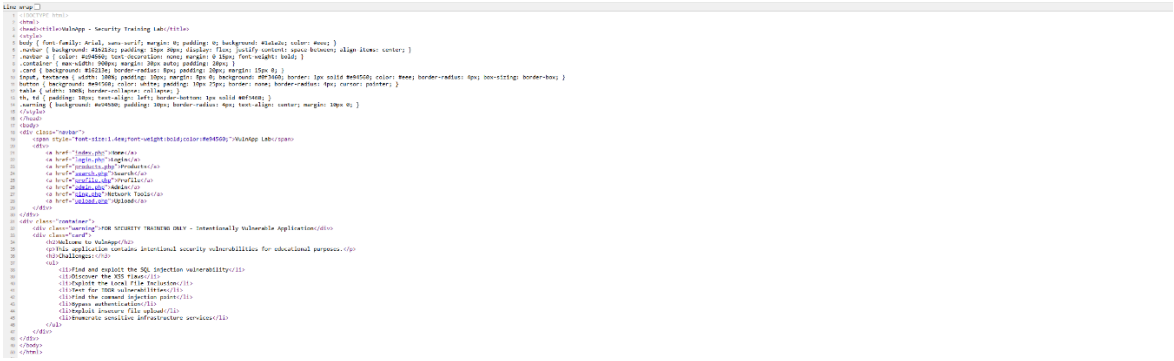
Top 5 Active Tests Justified by Passive Findings

1. Access control testing on (/admin.php) - Observation: Admin page is accessible from public navigation without authentication. Justification: Confirms the full extent of privileged functionality and data exposure available to unauthenticated users.
2. Injection testing on (/search.php) - Observation: HTML source indicates un-sanitized reflected output and XSS-related comments. Justification: Validates whether reflected XSS can be successfully executed.
3. SQL injection testing on (/login.php) - Observation: login reveals verbose backend query behavior, and the source shows weak form security controls. Justification: Determines whether authentication input is vulnerable to SQL injection.
4. Command injection testing on (/ping.php) - Observation: public network tool accepts host/IP input through a user-controlled field. Justification: Verifies whether user input is passed unsafely to system commands.
5. File inclusion testing on (/page.php?file=) - Observation: hidden endpoint /page.php reveals a user-controlled file parameter through on-page guidance (?file=welcome.html), indicating dynamic file-loading behavior. Justification: Test whether file-loading mechanisms can be abused to include unintended local files.

5. Technical Findings

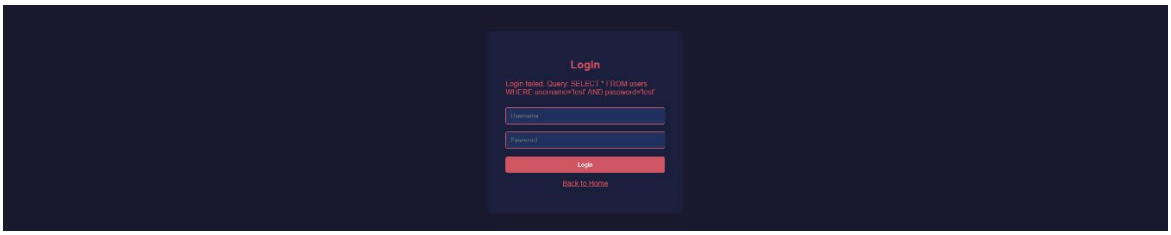
5.1 /index.php - Public Structure Disclosure





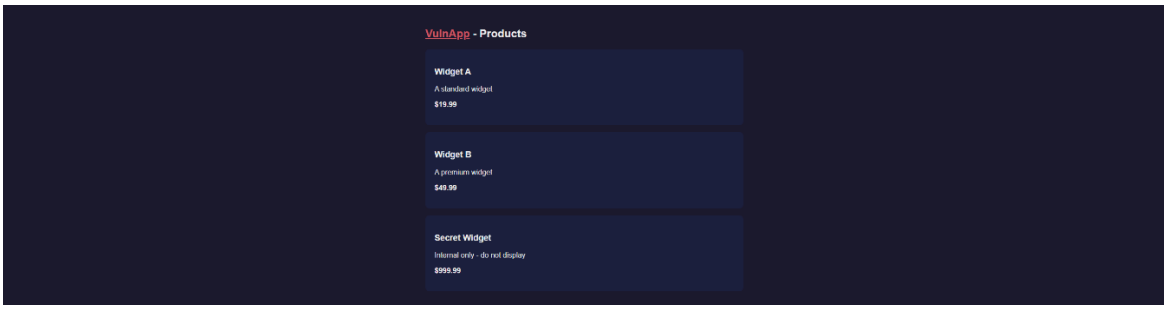
Home page exposes the application structure through direct links to sensitive endpoints with no secure control mechanism.

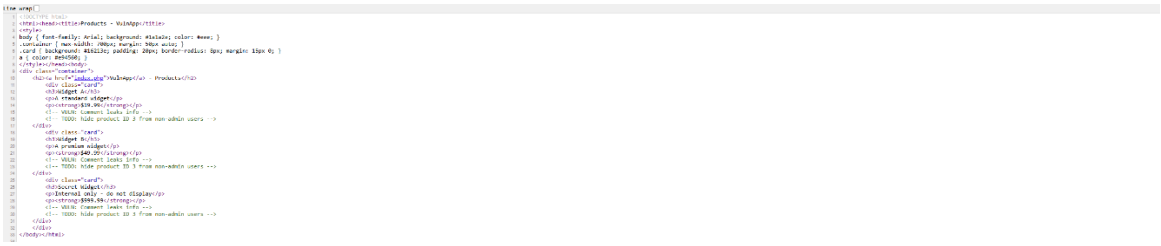
5.2 /login.php - Verbose Error Disclosure and Missing CSRF Protection



Login page source includes a comment indicating that no CSRF token is implemented and failed login attempts return verbose error information that exposes backend authentication behavior.

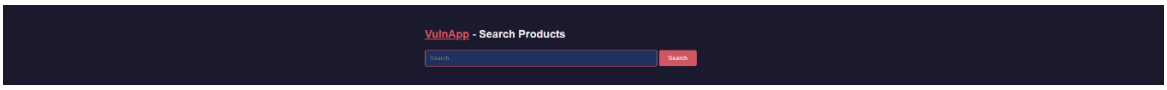
5.3 /products.php - Internal Content Exposure and HTML Comment Leakage

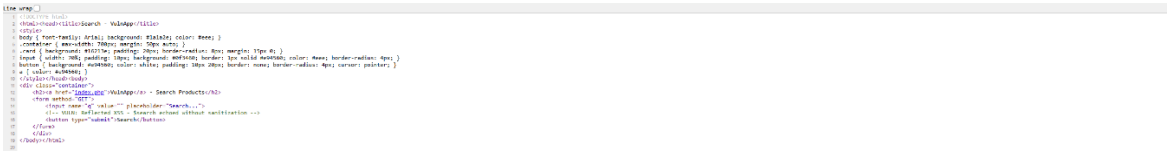


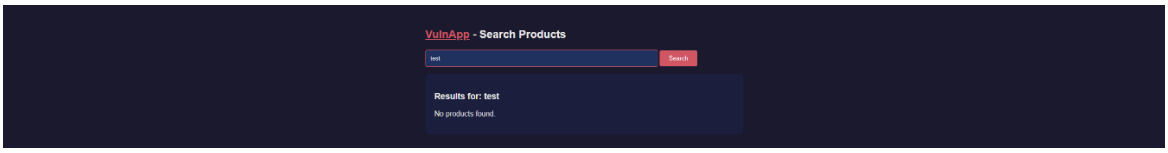


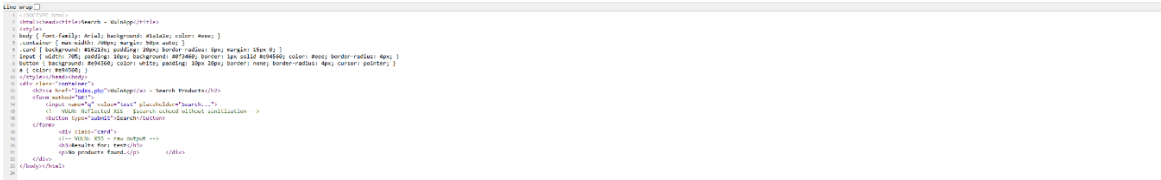
Products page exposes product names, descriptions, and prices, including an internal item labelled “Secret Widget” with the description of “Internal only - do not display.” HTML source inspection also revealed internal developer comments such as “TODO: hide product ID 3 from non-admin users”, indicating that a restricted content is exposed to public.

5.4 /search.php - Reflected XSS Evidence



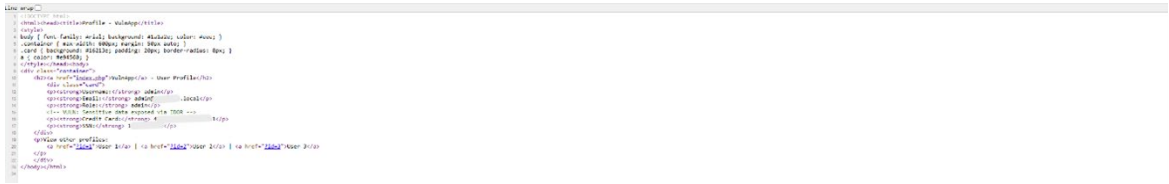


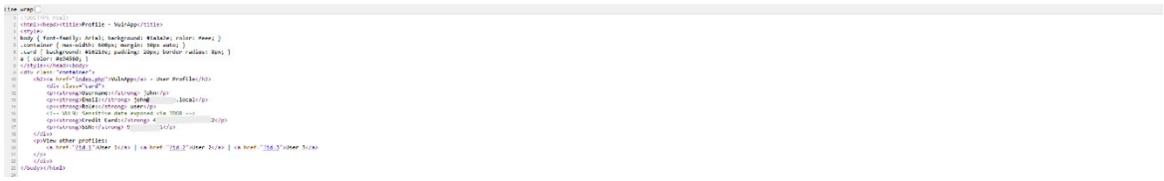




Search page reflects user inputs through q parameter. HTML source inspection revealed comments indicating reflected XSS and un-sanitized output, including reference to raw output handling mechanism.

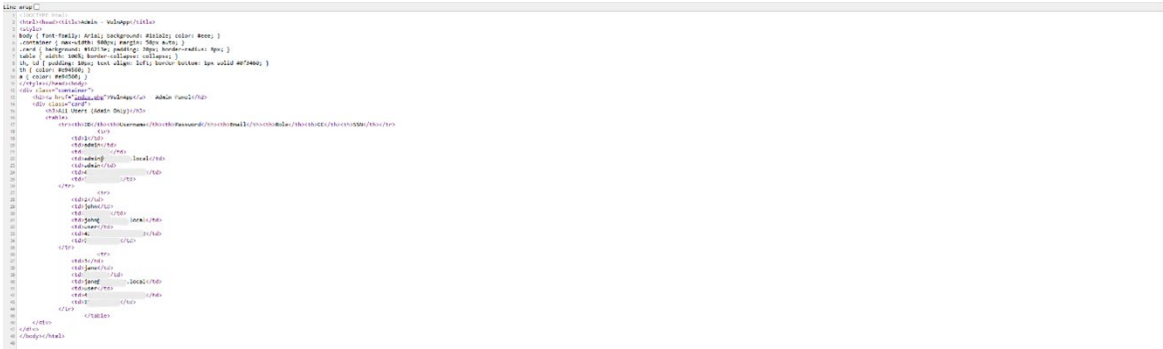
5.5 /profile.php - Insecure Direct Object Reference (IDOR) and PII Exposure





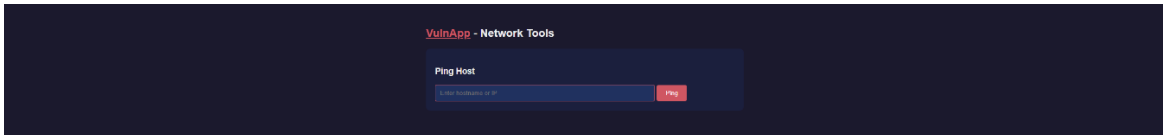
Profile page uses a predictable numeric “id” parameter and publicly exposes direct links to multiple profiles such as [id=1, id=2, id=3]. Which allows different user records to be accessed without authentication, and it contains personally identifiable information and user based financial details.

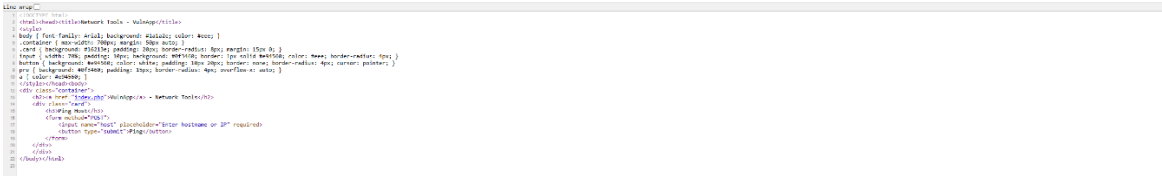
5.6 /admin.php - Unauthenticated Administrative Access



Administrator interface is directly accessible without any authentication through navigation. This page exposes administrative and sensitive user-related personal and financial data, indicating a complete failure to restrict privileged functionality from unauthenticated users.

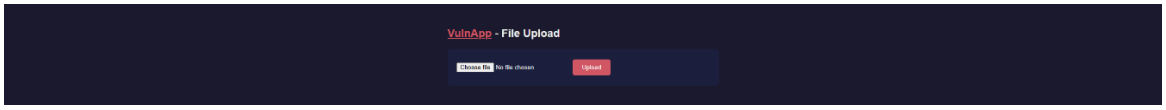
5.7 /ping.php - Publicly Exposed Network Utility

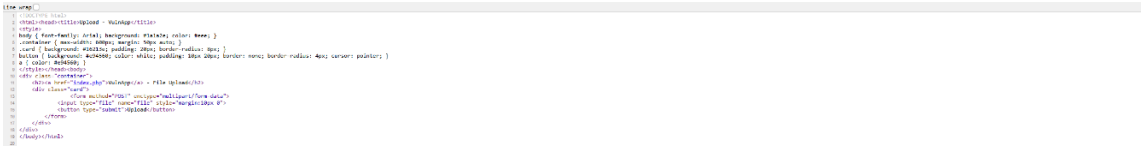




This network tools page exposes a host/IP input function which is publicly accessible. This has a risk of potential command injection.

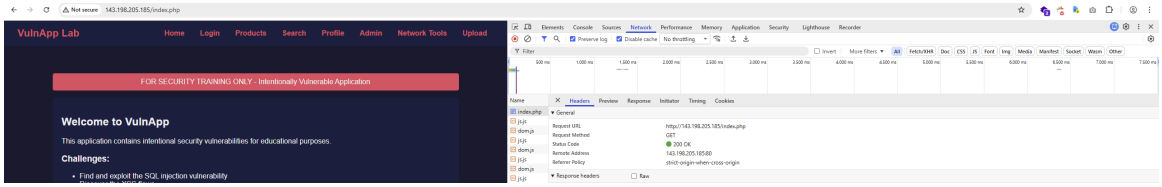
5.8 /upload.php - Public File Upload Function





File upload page is publicly accessible with no visible restrictions or validation controls which has a risk of potential insecure file upload.

5.9 Application-wide - No HTTPS



This application is served over HTTP rather than HTTPS, meaning traffic is not encrypted in transit. This has weak transport security.

5.10 Application-wide - Server Disclosure

Cache-Control	no-store, no-cache, must-revalidate
Connection	Keep-Alive
Content-Encoding	gzip
Content-Length	997
Content-Type	text/html; charset=UTF-8
Date	Thu, 26 Mar 2026 13:19:55 GMT
Expires	Thu, 19 Nov 1981 08:52:00 GMT
Keep-Alive	timeout=5, max=100
Pragma	no-cache
Server	Apache/2.4.58 (Ubuntu)
Vary	Accept-Encoding

Response headers reveal Server: Apache/2.4.58 (Ubuntu), disclosing backend infrastructure details.

*(View **References & Appendices** Section for other related technical findings)*

6. Risk Assessment Matrix

Findings (Top 6)	Endpoints	OWASP Category	Severity	Risk Rationale
Unauthenticated administrative access	/admin.php	A01 Broken Access Control	Critical	Privileged administrative functions are directly accessible without authentication, with critical risk of unauthorized access to sensitive data and management functions.
IDOR with PII exposure	/profile.php?id=	A01 Broken Access Control	Critical	Predictable numeric identifiers allow access to multiple user records, exposing sensitive user data without authorization.
Reflected XSS evidence	/search.php	A03 Injection	Critical	Source code explicitly indicates un-sanitized reflected output, strongly suggesting client-side code execution risk.
Server configurati	/info.php	A05 Security	High	Public exposure of PHP and Apache configuration details significantly

on disclosure		Misconfiguration		improves attacker reconnaissance and reveals internal environment information.
Internal content and comment leakage	/products.php	A05 Security Misconfiguration	High	Internal-only product data and developer comments are exposed publicly, indicating weak separation between public and restricted information.
No HTTPS / insecure transport	Application-wide	A02 Cryptographic Failures	High	All traffic is transmitted over HTTP, increasing the risk of interception, credential theft, and session compromise.

*(All other findings are represented on **Detailed Methodology** section in **Phase 5**)*

7. Recommendations and Active Scope

7.1 Recommendations

- Restrict administrative functionality by adding authentication and role-based access control - The admin.php endpoint should be removed from public access and should implement strong authentication and server-side authorization checks. This endpoint should not be exposed through public navigation menus.
- Enforce object level authorization for profile access - A validation should be implemented to validate the authorization of accessing user to the requested profile before returning any user data. Predictable direct reference such as “id” should not expose other user records.
- Implement output encoding and input validation for search - User input that reflects in /search.php should be properly encoded before rendering and server-side input validation should be applied to reduce injection risks.
- Strengthen login security controls - The login should include CSRF protection, and the errors related to authentication should be generalized so the backend logic or query behavior is not disclosed to users.
- Disable public access to development and configuration files - Hidden endpoints such as /info.php should be removed or restricted immediately. These development and diagnostic files should not be exposed in a public environment.
- Review dynamic file-loading design - The /page.php endpoint should not allow user-controlled file references. If dynamic content loading is required, only strict allow list should be allowed.

- Enforce HTTPS across the application - All the application traffic should be redirected to HTTPS, and the transport security should be strengthened with HSTS without transmitted over plain HTTP.
- Remove internal comments and segregate internal product data - The developer comments or internal-only comments shouldn't be exposed to public pages (e.g.: /profile.php). Without relying on front-end hiding, product visibility rules should be enforced on server-side.
- Restrict or harden high-risk utility endpoints - Public exposure of /ping.php and /upload.php should be reconsidered. If these are required, restrictions must be implemented to access only by authorized users and protected by strict server-side validation.
- Reduce infrastructure disclosure - Infrastructure and service details which are publicly disclosed should be minimized where possible. External services such as SSH should be reviewed for necessity, exposure, and hardening (e.g.: /info.php).

7.2 Active Assessment Scope

Based on the conducted passive reconnaissance, following areas are recommended for controlled active testing in next phase,

- Access control testing on /admin.php - Justified by the passive observation of administrative functionality is accessible without authentication.
- Authorization and record scope testing on /profile.php - Justified by the confirmed IDOR pattern and public links to multiple user profiles.
- Reflected XSS testing on /search.php - justified by the HTML source comments that explicitly indicating un-sanitized reflected output.
- SQL injection testing on /login.php - Justified by the verbose backend query behavior during failed login attempts.
- File inclusion testing on /page.php - Justified by the hidden endpoint that exposes user-controlled file loading parameter.
- Command injection testing on /ping.php - Justified by the publicly accessible network utility page which accepts host/IP inputs.
- File upload security testing on /upload.php - Justified by the publicly accessible page with upload functionality without any visible validation controls.

These recommended active tests are based directly on findings of passive reconnaissance and should be conducted only in an authorized penetration testing phase.

8. References and Appendices

8.1 References

Standards and Guidance

OWASP Foundation (2021) *OWASP Top 10:2021*. Available at: https://owasp.org/Top10/2021/ (Accessed: 28 March 2026).

OWASP Foundation (n.d.) *OWASP Web Security Testing Guide v4.2*. Available at: https://owasp.org/www-project-web-security-testing-guide/v42/ (Accessed: 28 March 2026).

Tools and External Sources

- Google Chrome Developer Tools
- Burp Suite Community Edition
- Wappalyzer
- Wayback Machine
- Shodan
- Mozilla Firefox
- GoFullPage Browser Extension
- SingleFile Browser Extension

8.2 Appendices

Appendix A - URL List

http://143.198.205.185/index.php

http://143.198.205.185/login.php

http://143.198.205.185/products.php

http://143.198.205.185/search.php

http://143.198.205.185/profile.php

http://143.198.205.185/profile.php?id=1

http://143.198.205.185/profile.php?id=2

http://143.198.205.185/profile.php?id=3

http://143.198.205.185/admin.php

http://143.198.205.185/ping.php

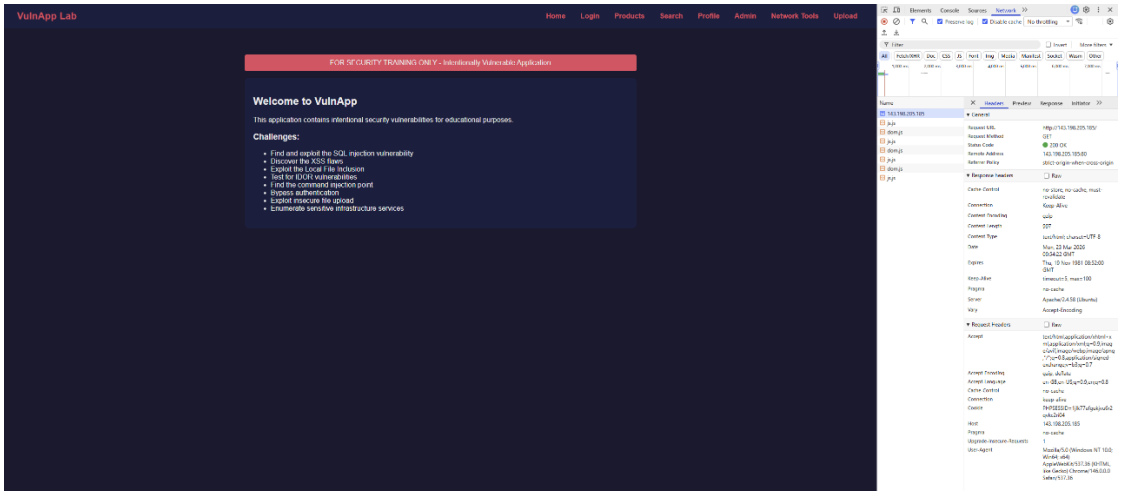
http://143.198.205.185/upload.php

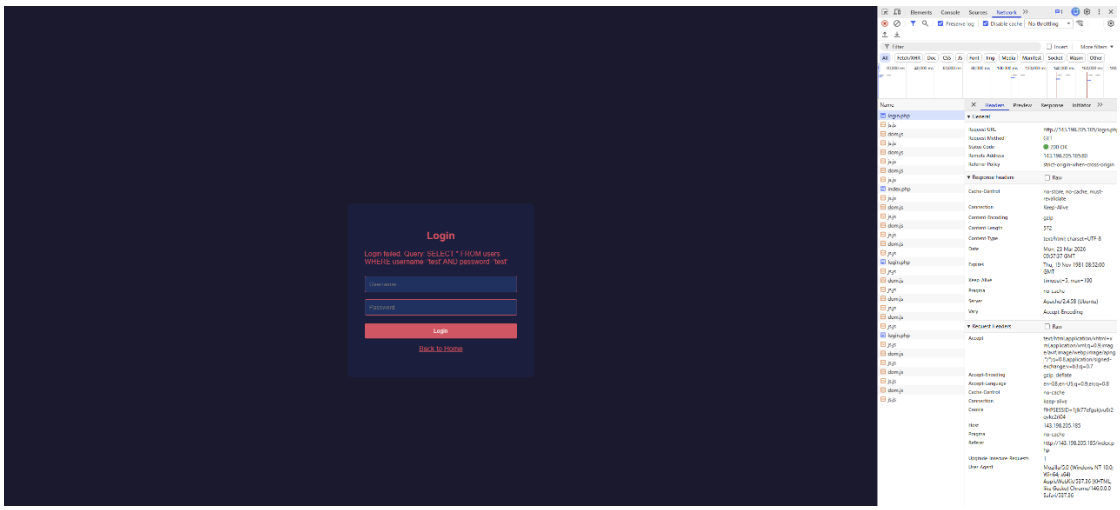
http://143.198.205.185/page.php

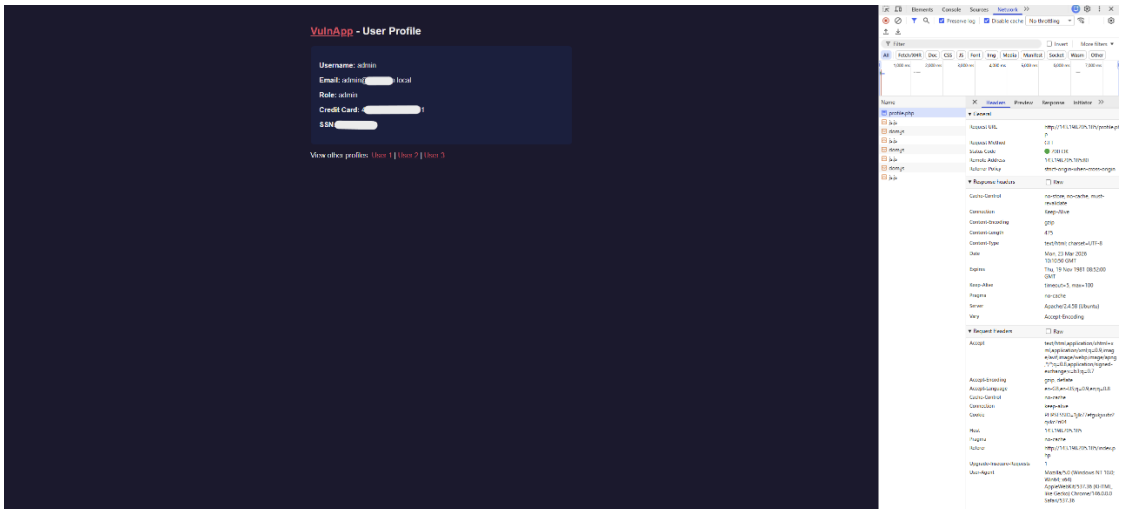
http://143.198.205.185/page.php?file=welcome.html

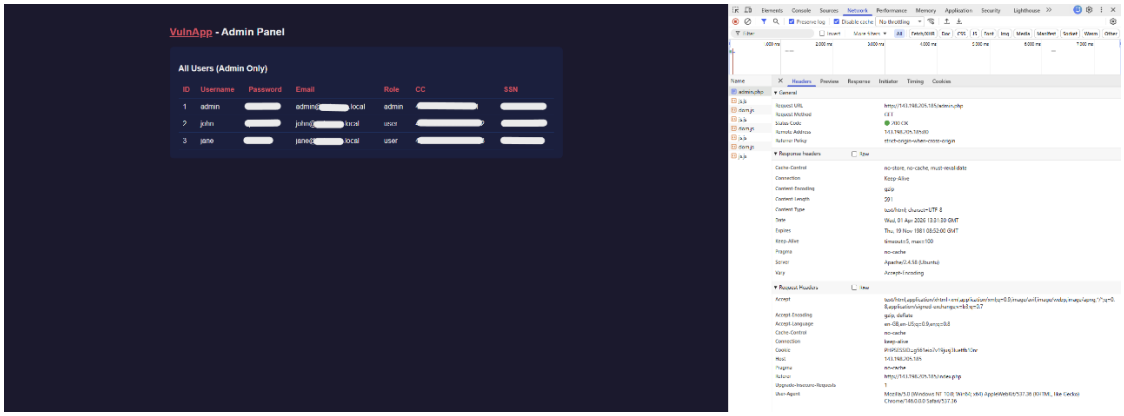
http://143.198.205.185/info.php

Appendix B - HTTP Header Evidence



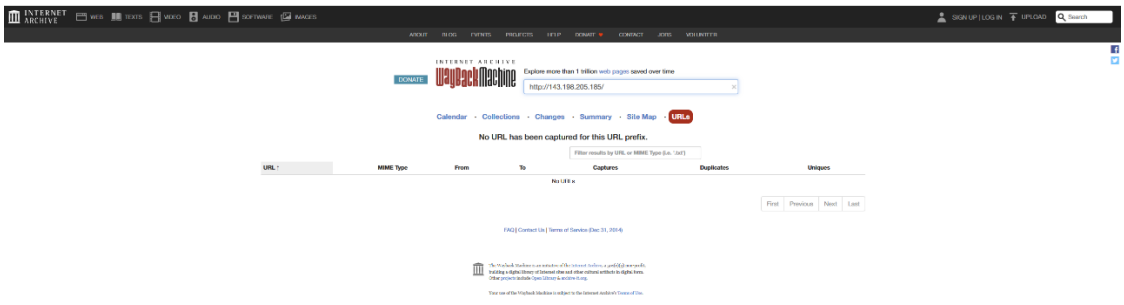



VulnApp - User Profile
Username: admin
Email: admin[redacted].local
Role: admin
Credit Card: [redacted]
SSN [redacted]
View other profiles: User 1 | User 2 | User 3

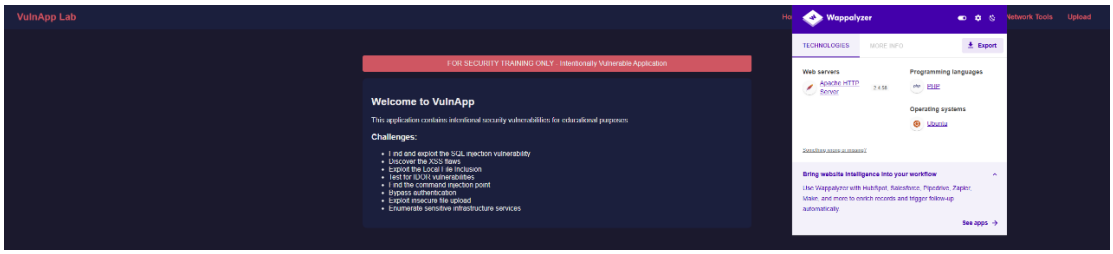

VulnApp - Admin Panel
All Users (Admin Only)
ID Username Password Email Role CC SSN
1 admin [redacted] admin[redacted].local admin [redacted]
2 john [redacted] john@[redacted].local user [redacted]
3 jane [redacted] jane[redacted].local user [redacted]

VulnApp - Pages
Welcome
Select a page to view. Try: /file=welcome.html

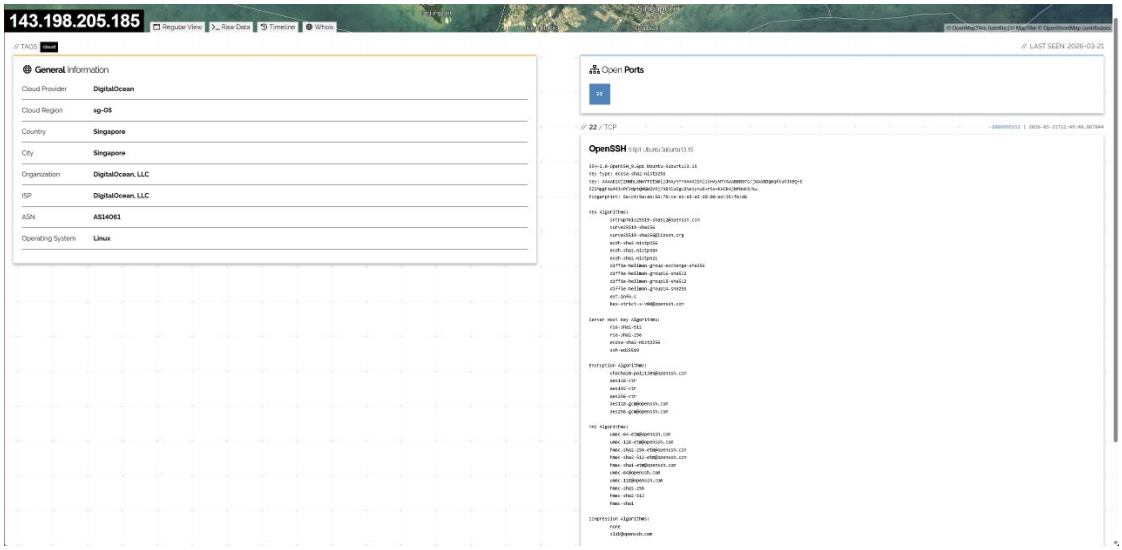
Appendix C - Other Evidence



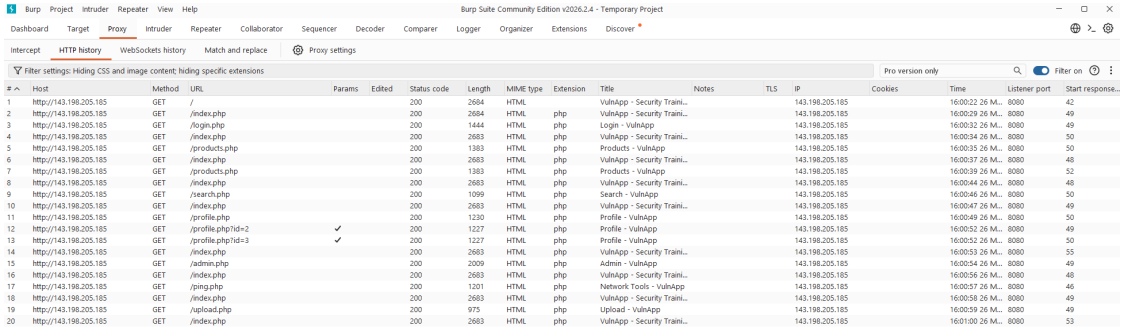
Wayback Machine findings



Wappalyzer findings

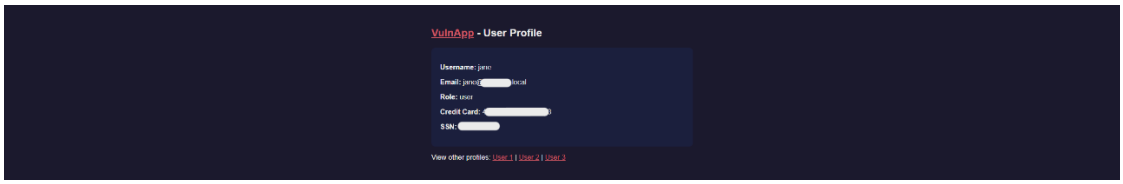


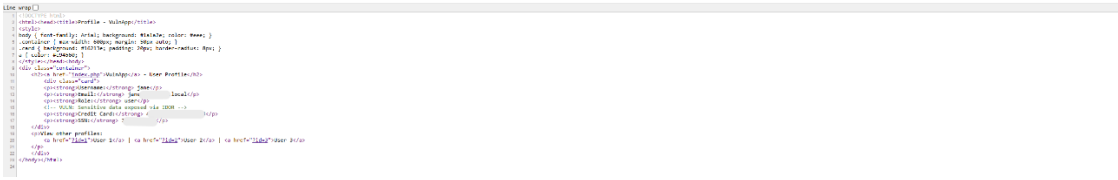
Shodan findings



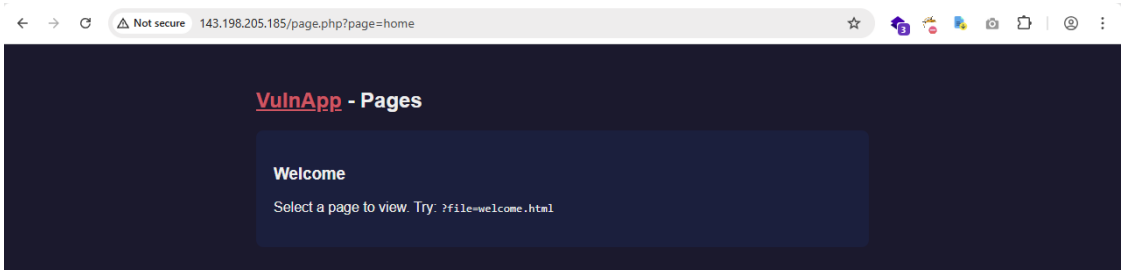
#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start response...
1	http://143.198.205.185	GET	/			200	2684	HTML		VulnApp - Security Traini...			143.198.205.185		16:00:22 26 M...	8080	42
2	http://143.198.205.185	GET	/index.php			200	2684	HTML	php	VulnApp - Security Traini...			143.198.205.185		16:00:29 26 M...	8080	49
3	http://143.198.205.185	GET	/login.php			200	1444	HTML	php	Login - VulnApp			143.198.205.185		16:00:32 26 M...	8080	49
4	http://143.198.205.185	GET	/index.php			200	2683	HTML	php	VulnApp - Security Traini...			143.198.205.185		16:00:34 26 M...	8080	50
5	http://143.198.205.185	GET	/products.php			200	1383	HTML	php	Products - VulnApp			143.198.205.185		16:00:35 26 M...	8080	50
6	http://143.198.205.185	GET	/index.php			200	2683	HTML	php	VulnApp - Security Traini...			143.198.205.185		16:00:37 26 M...	8080	48
7	http://143.198.205.185	GET	/products.php			200	1383	HTML	php	Products - VulnApp			143.198.205.185		16:00:39 26 M...	8080	52
8	http://143.198.205.185	GET	/index.php			200	2683	HTML	php	VulnApp - Security Traini...			143.198.205.185		16:00:44 26 M...	8080	48
9	http://143.198.205.185	GET	/search.php			200	1099	HTML	php	Search - VulnApp			143.198.205.185		16:00:46 26 M...	8080	50
10	http://143.198.205.185	GET	/index.php			200	2683	HTML	php	VulnApp - Security Traini...			143.198.205.185		16:00:47 26 M...	8080	49
11	http://143.198.205.185	GET	/profile.php			200	1230	HTML	php	Profile - VulnApp			143.198.205.185		16:00:49 26 M...	8080	50
12	http://143.198.205.185	GET	/profile.php?id=2	✓		200	1227	HTML	php	Profile - VulnApp			143.198.205.185		16:00:52 26 M...	8080	49
13	http://143.198.205.185	GET	/profile.php?id=3	✓		200	1227	HTML	php	Profile - VulnApp			143.198.205.185		16:00:52 26 M...	8080	50
14	http://143.198.205.185	GET	/index.php			200	2683	HTML	php	VulnApp - Security Traini...			143.198.205.185		16:00:53 26 M...	8080	55
15	http://143.198.205.185	GET	/admin.php			200	2009	HTML	php	Admin - VulnApp			143.198.205.185		16:00:54 26 M...	8080	49
16	http://143.198.205.185	GET	/index.php			200	2683	HTML	php	VulnApp - Security Traini...			143.198.205.185		16:00:56 26 M...	8080	48
17	http://143.198.205.185	GET	/ping.php			200	1201	HTML	php	Network Tools - VulnApp			143.198.205.185		16:00:57 26 M...	8080	46
18	http://143.198.205.185	GET	/index.php			200	2683	HTML	php	VulnApp - Security Traini...			143.198.205.185		16:00:58 26 M...	8080	49
19	http://143.198.205.185	GET	/upload.php			200	975	HTML	php	Upload - VulnApp			143.198.205.185		16:00:59 26 M...	8080	49
20	http://143.198.205.185	GET	/index.php			200	2683	HTML	php	VulnApp - Security Traini...			143.198.205.185		16:01:00 26 M...	8080	53

Burp Suite findings (Passive Proxy Mode)

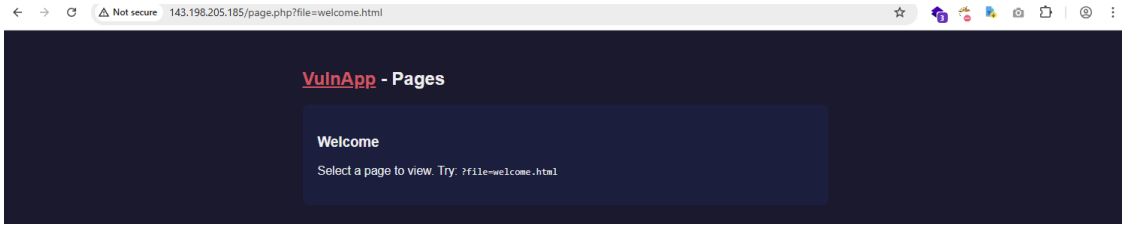




User Profile 3



Hidden Endpoint found (/page.php)



Endpoint exposed parameter's page (?file=welcome.html)

Exposed server configurations and details (/info.php)

END